continuous authorization. Instead of granting broad, durable access once a principal authenticates, Zero Trust requires that every access be evaluated in context: who is making the request, from what device, under what conditions, and for what purpose.

Sam had heard versions of this argument at conferences for years, but the vendor noise often masked the core idea. Products claimed to deliver Zero Trust, but none could explain how a device at the network's edge was supposed to fix the architectural mismatch ACME faced. As Sam came to understand, Zero Trust can’t be achieved by simply buying a product or tightening the perimeter, because the perimeter no longer exists.

Zero Trust requires a different foundation. ACME needed strong authentication that provided consistent identity signals, reliable role, attribute, and relationship data, trustworthy device posture, and operational signals such as on-call status or recent approvals on high-risk actions from managers or other team members. These signals required governance to ensure they remained defined, validated, and up to date. Most importantly, ACME needed a way to evaluate every access request against a coherent set of policies, quickly and consistently across all systems.

Taken together, these requirements shifted focus from network boundaries to authorization, a decision system capable of evaluating every request based on identity, device posture, and context. The question for ACME was whether its current authorization framework could support this shift. The next section explores how this realization transformed ACME’s access-decision architecture and how PBAC became the core element of the company’s Zero Trust approach.

15.2 Authorization is the foundation of Zero Trust

To support this shift, ACME needed an authorization architecture that could assess every access request based on identity, device posture, and contextual signals, regardless of the request’s origin.

Figure 15.2 shows how this works. Each access request, no matter where it comes from, is ultimately assessed by a policy engine using details such as